Parul® University
Vadodara, Gujarat

NAAC GRADE A++

Information and Communication Technology

Metasploit Frame work 303105324

Mr Bibungsarth Islary
Assistant Professor
CSE (Cyber Security)

Content

1. Server-Side Exploitation Fundamentals
2. Exploitation Methodology
3. Metasploit Exploitation Architecture
4. Exploiting a Linux Server
5. Linux Privilege Context
6. Exploiting a Windows Machine
7. Windows Services and Attack Surface
8. Exploiting Common Services
9. Payloads and Handlers
10. Sessions and Post-Exploitation
11. Failed Exploitation and Troubleshooting
12. Attack Path and Attack Graph
13. Detection and DFIR
14. Case Studies
15. Practical Exercises

Server-Side Exploitation

Server-side exploitation is the process of taking advantage of a vulnerability in a service or application running on a server.

Basic concept

Attacker
↓
Network
↓
Server
↓
Vulnerable Service
↓
Vulnerability
↓
Code / Command Execution
↓
Session

Main objective

Gain unauthorized execution or access within an authorized security assessment.

Server Attack Surface

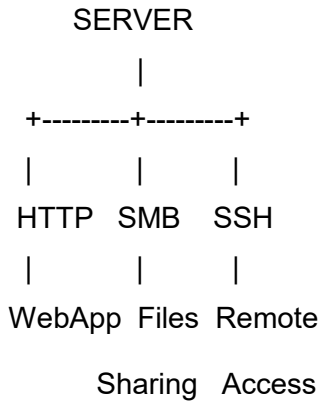
A server may expose multiple services.

Examples

- HTTP / HTTPS
- FTP
- SSH
- SMB
- RDP
- DNS
- SMTP
- Databases
- Remote administration services

Important idea

Every exposed service represents a potential attack surface.



Exploitation Chain

Server exploitation usually follows a sequence.

Reconnaissance

↓

Service Discovery

↓

Version Identification

↓

Vulnerability Identification

↓

Exploit Selection

↓

Target Configuration

↓

Exploit Attempt

↓

Session

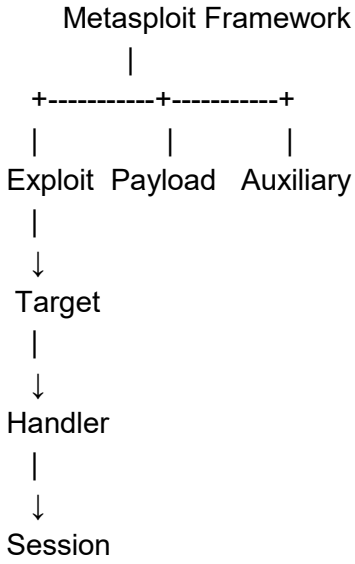
↓

Post-Exploitation

↓

Evidence / Reporting

Metasploit Exploitation Architecture



Major components

- Exploit
- Payload
- Handler
- Target
- Session
- Auxiliary modules

Exploit Module

An exploit module contains the logic required to take advantage of a specific vulnerability.

Concept

Vulnerable Service
↓
Vulnerability
↓
Exploit Module
↓
Target System

Exploit module may depend on

- Product
- Version
- Operating system
- Architecture
- Target configuration
- Vulnerability conditions

Payload

A payload defines what happens after successful exploitation.

Examples of objectives

- Command execution
- Interactive session
- Meterpreter session

Exploit
↓
Successful Execution
↓
Payload
↓
Session

Important distinction

Exploit = How access is obtained

Payload = What executes after access

Exploit vs Payload

Exploit	Payload
Targets vulnerability	Defines post-exploitation behavior
Gains execution	Executes functionality
Depends on vulnerability	Depends on target compatibility
Often target-specific	May have multiple options

Example

Vulnerability
↓
Exploit
↓
Payload
↓
Meterpreter Session

Handler

A handler waits for and manages incoming connections from a payload.

Target
|
| Payload Connection
↓
Metasploit Handler
↓
Session

Handler configuration may include

- Local host
- Local port
- Payload type
- Communication method

Security perspective

Unexpected outbound connections can be important detection signals.

Basic Exploitation Workflow

search
↓
use
↓
info
↓
show options
↓
set required options
↓
check
↓
run / exploit
↓
session

Important

Each step provides information before the next action.

Module Discovery

Metasploit contains modules for different vulnerabilities and services.

Conceptual workflow

Service
↓
Product
↓
Version
↓
Vulnerability
↓
Metasploit Module

Useful commands

search <keyword>
info <module>

Example

search type:exploit platform:linux

Information Before Exploitation

Before running an exploit, determine:

- Target IP
- Open ports
- Running services
- Service versions
- Operating system
- Architecture
- Vulnerability
- Exploit compatibility
- Required options

Principle

> Do not exploit what you have not understood.

Linux Server Exploitation

Linux servers commonly expose:

- SSH
- FTP
- HTTP/HTTPS
- SMB
- DNS
- Databases
- Custom applications

Attacker
↓
Linux Server
↓
Exposed Service
↓
Vulnerability
↓
Exploit
↓
Shell / Session

Linux Server Attack Surface

Component	Possible Attack Surface
SSH	Authentication / configuration
FTP	Service vulnerabilities
HTTP	Web applications
SMB	File sharing
Database	Authentication / software vulnerabilities
Custom service	Application-specific vulnerabilities

The operating system is not necessarily the vulnerability. The **service running on it** may be the entry point.

Linux Exploitation Workflow

Discover Linux Host

↓

Identify Services

↓

Identify Versions

↓

Research Vulnerability

↓

Select Exploit

↓

Select Payload

↓

Configure Target

↓

Exploit

↓

Verify Session

Linux Service Enumeration

Service enumeration attempts to identify what the server exposes.

Questions

- Which ports are open?
- Which services are running?
- What versions are installed?
- Is authentication required?
- Is the service remotely accessible?
- Does the service have a known vulnerability?

Example

Port 21 → FTP
Port 22 → SSH
Port 80 → HTTP
Port 443 → HTTPS

FTP Server Exploitation

FTP commonly operates on:

TCP 21

Potential security issues:

- Weak authentication
- Anonymous access
- Misconfiguration
- Vulnerable FTP software
- Outdated service versions

Attacker
↓
FTP : 21
↓
Vulnerable FTP Service
↓
Exploit
↓
Session

SSH Service

SSH provides remote administration.

Default port

TCP 22

Security considerations:

- Authentication
- Password policy
- Key management
- Configuration
- Software version
- User privileges

Important

SSH itself is not automatically vulnerable simply because it is exposed.

Linux Web Server Exploitation

Web services are common entry points.

Browser / Attacker
↓
HTTP / HTTPS
↓
Web Server
↓
Application
↓
Vulnerability
↓
Code Execution

Possible weaknesses:

- Outdated software
- Vulnerable web application
- Improper input validation
- File handling vulnerabilities
- Authentication weaknesses

Linux Payload Selection

Payload selection depends on:

- Target OS
- Architecture
- Available network path
- Required session type
- Exploit compatibility

Linux Target

↓

Architecture

↓

Compatible Payload

↓

Execution

↓

Session

A correct exploit with an incompatible payload may still fail.

Linux Session

After successful exploitation, verify the obtained context.

Important questions:

- Which user am I?
- What operating system is running?
- What privileges are available?
- What network interfaces exist?
- What services are accessible?

Example concepts

getuid

sysinfo

Linux Privilege Context

A successful exploit does not necessarily mean root access.

Exploit

↓

Low-Privilege User

↓

Privilege Escalation

↓

Root

Security principle

Initial access ≠ administrative control

Linux Post-Exploitation

Once a session exists, an authorized tester may examine:

- User context
- System information
- Network configuration
- Running processes
- Services
- File permissions
- Security configuration

Objective

Understand the impact of the compromise.

Linux Exploitation Case Study

Scenario

A Linux server exposes:

22/tcp → SSH

80/tcp → HTTP

HTTP identifies an outdated vulnerable application.

Task

Identify the attack path and possible defensive controls.

Attack path

Internet / Lab Network

↓

TCP 80

↓

Web Application

↓

Known Vulnerability

↓

Exploit

↓

Payload

↓

Low-Privilege Session.

Windows Machine Exploitation

Windows systems commonly expose:

- SMB
- RDP
- HTTP/HTTPS
- WinRM
- FTP
- Remote administration services

Attacker

↓

Windows Host

↓

Exposed Service

↓

Vulnerability

↓

Exploit

↓

Session

Windows Attack Surface

Service	Common Port
SMB	445
RDP	3389
HTTP	80
HTTPS	443
WinRM	5985/5986
FTP	21

Important

Port numbers identify services but do not prove that a service is vulnerable.

Windows Exploitation Workflow

Host Discovery

↓

Port Enumeration

↓

Service Identification

↓

Version Detection

↓

Vulnerability Analysis

↓

Exploit Selection

↓

Payload Selection

↓

Execution

↓

Session

SMB Service

SMB is widely used for Windows file and resource sharing.

Common port

TCP 445

Security relevance:

- File sharing
- Authentication
- Remote service interaction
- Lateral movement
- Vulnerable implementations

Client

↓

SMB

↓

Windows Server

↓

Shared Resources

SMB Exploitation

Potential attack chain:

SMB Discovery

↓

Version Identification

↓

Vulnerability Identification

↓

Exploit

↓

Code Execution

↓

Payload

↓

Session

Defensive perspective

Monitor:

- SMB connections
- Unusual source hosts
- Authentication failures
- Remote service activity
- Suspicious process creation

Remote Desktop Protocol

RDP provides graphical remote access to Windows systems.

Default port

TCP 3389

Architecture:

Remote Client

↓

Network

↓

RDP Service

↓

Windows Desktop

RDP Security Considerations

Potential risks:

- Weak credentials
- Exposed RDP
- Missing security controls
- Outdated implementations
- Excessive privileges

Defensive controls:

- Network restrictions
- Strong authentication
- NLA
- MFA where available
- Account lockout policies
- Monitoring

Windows Payload

A Windows payload must match the target environment.

Consider:

- Windows version
- Architecture
- Exploit compatibility
- Network connectivity
- Session requirements

Windows Vulnerability

↓

Compatible Exploit

↓

Compatible Payload

↓

Session

Windows Session Verification

After obtaining a session, determine:

- Current user
- System information
- Privilege level
- Process context
- Network configuration

Conceptual commands:

getuid

sysinfo

Question

Is the session running as:

Standard User

or

Administrator

or

SYSTEM

Windows Privilege Context

Initial Exploit

↓

User Context

↓

Privilege Escalation

↓

Administrator / SYSTEM

Important

The impact of exploitation depends heavily on the security context obtained.

Common Service Exploitation

Common server services include:

- FTP
- SSH
- SMB
- HTTP
- HTTPS
- RDP
- Databases

Methodology

Service

↓

Version

↓

Vulnerability

↓

Exploit

↓

Payload

↓

Session

Service-Based Exploitation

The service becomes the attack entry point.

Target

|

+--- FTP

|

+--- SSH

|

+--- SMB

|

+--- HTTP

|

+--- RDP

|

+--- Database

Each service has:

- Protocol
- Port
- Authentication
- Software implementation
- Configuration
- Vulnerabilities

FTP Attack Surface

Potential weaknesses:

- Anonymous access
- Weak credentials
- Vulnerable software
- Poor permissions
- Clear-text authentication
- Misconfiguration

Detection

Monitor:

- FTP connections
- Authentication failures
- Unusual source addresses
- Large file transfers
- Unexpected commands

SSH Attack Surface

Potential concerns:

- Weak authentication
- Exposed service
- Outdated implementation
- Misconfigured accounts
- Excessive privileges

Defensive controls

- Key-based authentication
- Strong passwords
- Network restrictions
- MFA where supported
- Account monitoring
- Patch management

HTTP/HTTPS ATTACK SURFACE

Web servers expose applications to remote clients.

Potential weaknesses:

- Vulnerable software
- Authentication flaws
- Input validation issues
- File handling vulnerabilities
- Misconfiguration
- Outdated frameworks

HTTP Request

↓

Web Server

↓

Application

↓

Vulnerable Component

↓

Execution / Data Exposure

Database Services

Examples:

- MySQL
- PostgreSQL
- MSSQL
- Oracle

Security concerns:

- Weak credentials
- Exposed database ports
- Misconfiguration
- Vulnerable software
- Excessive privileges

Important

A database service should generally not be directly exposed unnecessarily.

Service Comparison

Service	Typical Port	Main Security Concern
FTP	21	Authentication / vulnerable implementation
SSH	22	Authentication / configuration
HTTP	80	Web application vulnerabilities
HTTPS	443	Web application vulnerabilities
SMB	445	Remote service / file sharing vulnerabilities
RDP	3389	Remote access / authentication
Database	Various	Authentication / configuration

Finding a Metasploit Module

Use module discovery to identify possible modules.

search <keyword>

Examples:

search ftp

search smb

search apache

Goal

Find modules related to the identified service or vulnerability.

Understanding a Module

Before using a module:

info <module>

Study:

- Description
- Vulnerability
- References
- Targets
- Options
- Payload compatibility

Principle

Understand the exploit before executing it.

Module Configuration

show options

Important parameters may include:

- RHOSTS
- RPORT
- LHOST
- LPORT
- Payload-specific options

Target

↓

RHOSTS

↓

Service

↓

RPORT

Vulnerability Verification

Some modules support:

check

Conceptually:

Target

↓

Check

↓

Likely Vulnerable

OR

Not Vulnerable

OR

Unknown

Important

A check result is not always proof of exploitation success.

Exploitation

After configuring the authorized lab target:

run

or

exploit

Possible outcomes:

Successful

↓

Session

Failed

↓

Troubleshooting

Session Management

When a session is created:

sessions

A tester may:

- List sessions
- Interact with a session
- Background a session
- Close a session

Concept:

Exploit

↓

Session ID

↓

Interact

↓

Post-Exploitation

Session Verification

After exploitation, verify:

Identity

getuid

System

sysinfo

Then determine:

- OS
- Architecture
- User
- Privileges
- Session type

Question

Did exploitation achieve the intended objective?

Exploitation Failure

An exploit may fail because of:

- Wrong target
- Wrong version
- Wrong target type
- Incorrect options
- Incompatible payload
- Network connectivity
- Firewall
- Patched vulnerability
- Architecture mismatch
- Service unavailable

Exploit Failure

↓

Check Assumptions

↓

Verify Target

↓

Verify Configuration

↓

Verify Compatibility

Troubleshooting Methodology

1. Is the host reachable?

↓

2. Is the service running?

↓

3. Is the expected port correct?

↓

4. Is the version vulnerable?

↓

5. Is the exploit appropriate?

↓

6. Is the payload compatible?

↓

7. Is the network path correct?

Do not randomly change exploit options. Identify the failed assumption.

Exploitation Telemetry

Possible sequence:

Unusual Network Connection

+

Suspicious Service Activity

+

Unexpected Process Creation

+

Privilege Change

↓

Potential Exploitation

SOC principle

Correlation increases confidence.

Case Study: Linux Server

Scenario

A Linux server generates:

- Unusual HTTP request
- Unexpected process creation
- Outbound connection
- New user activity
- Privilege change

Student questions

1. What could be the initial access vector?
2. Which event should occur first?
3. What could indicate successful exploitation?
4. What evidence should be collected?
5. How would you build the attack timeline?

Case Study: Windows Machine

Scenario

A Windows server generates:

- Unusual SMB connection
- Suspicious process creation
- New outbound connection
- Privilege change
- Administrative activity

Student questions

1. Identify the possible attack path.
2. Which event could indicate initial access?
3. Which event indicates post-exploitation?
4. What endpoint telemetry is required?
5. What network telemetry is required?

Linux Server Exploitation

Understand the complete exploitation workflow against an intentionally vulnerable Linux machine.

Workflow

Identify Service

↓

Identify Version

↓

Find Vulnerability

↓

Search Metasploit

↓

Analyze Module

↓

Configure Target

↓

Check

↓

Exploit

↓

Verify Session

Windows Machine Exploitation

Understand exploitation of an intentionally vulnerable Windows machine.

Tasks

- Identify exposed services
- Identify service/version
- Find applicable vulnerability
- Select appropriate Metasploit module
- Configure required options
- Attempt exploitation
- Verify obtained session
- Identify privilege context

Post-Lab

Create an attack path diagram.

Common Service Exploitation

Objective

Compare exploitation opportunities across common services.

Services

- FTP
- SSH
- HTTP
- SMB
- RDP

Student task

For each service identify:

Port
↓
Service
↓
Version
↓
Potential Vulnerability
↓
Possible Exploit
↓
Expected Impact
↓
Detection Method

Final Deliverable

Create a **service-to-exploitation attack graph**.

Parul® University | NAAC GRADE A++

https://paruluniversity.ac.in/

